

---

# E-Commerce Security

CCY2001 — Introduction to Cyber Security

---

Dr. Hany Elshall — CCIT



- 1 Introduction to E-Commerce
- 2 E-Commerce Security Fundamentals
- 3 Security Threats
- 4 Security Protocols
- 5 Best Practices — Businesses
- 6 Best Practices — Consumers

# Introduction to E-Commerce

CCY2001 — Introduction to Cybersecurity

# What Is E-Commerce?

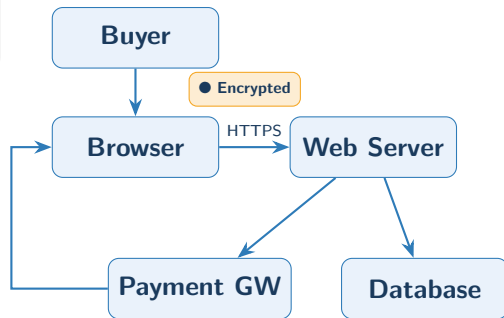
## Definition

The process of **buying and selling** products or services online, including the digital exchange of money and data.

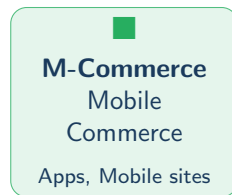
- Covers online retail, digital services, marketplaces, and payment systems
- Accelerated by COVID-19 and the rise of mobile devices
- Central to modern economies worldwide

## Security Challenge

Growing online data flows make **security and consumer protection** critical concerns.



# Key Types of E-Commerce



Each model faces **unique** security considerations — B2B handles bulk financial data; M-commerce exposes mobile endpoints.

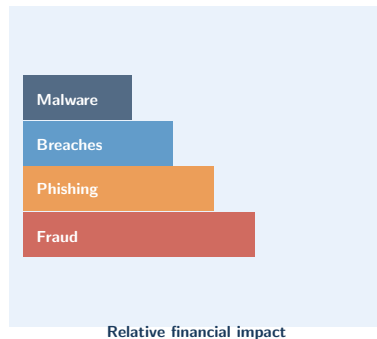
# The E-Commerce Threat Landscape

## Key Statistics

- > 50% of online shoppers **fear data breaches**
- Fraud losses projected to exceed **\$48 billion** (2023)
- Phishing, payment fraud, and data breaches are top threats

## Key Countermeasures

- SSL/TLS encryption
- Two-Factor Authentication (2FA)
- AI-based fraud detection
- Regular security audits



# E-Commerce Security Fundamentals

CCY2001 — Introduction to Cybersecurity

# What Is E-Commerce Security?

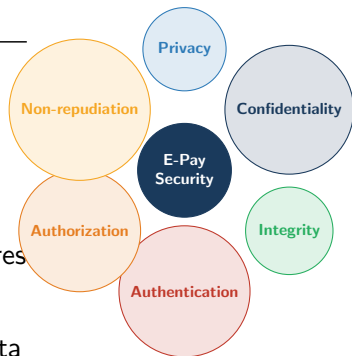
The set of **tools, techniques, and protocols** that protect online transactions, customer data, and business systems from threats such as fraud, hacking, and data breaches.



- Ensures **safe buying/selling** environments
- Prevents significant **financial and reputational** damage
- Key mechanisms: SSL encryption, authentication, integrity, AI fraud detection

# Security Requirements for E-Payments

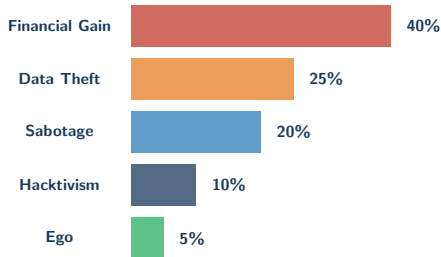
| Property                 | Meaning                              |
|--------------------------|--------------------------------------|
| ● <b>Confidentiality</b> | Encrypt sensitive data in transit    |
| ✓ <b>Integrity</b>       | Data unchanged during transfer       |
| ■ <b>Authentication</b>  | Verify user & server identity        |
| ⇒ <b>Authorization</b>   | Control permitted actions            |
| 📄 <b>Non-repudiation</b> | Deny-proof logs & digital signatures |
| ○ <b>Availability</b>    | Systems accessible, DoS-resistant    |
| ◆ <b>Privacy</b>         | Safeguard personal & financial data  |



# Why Do Attackers Target E-Commerce?

Attackers have varied motivations — from financial gain to ego:

- \$ Steal **financial data** (cards, banking)
- Access **confidential** company/user info
- 📎 **Alter, corrupt,** or delete stored data
- 👉 **Manipulate** system behaviour
- ✖ **Deny access** to legitimate users (DoS)
- ★ Demonstrate **technical skill** (ego-driven)



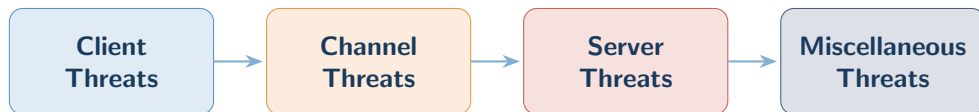
Motivation breakdown

# Security Threats

CCY2001 — Introduction to Cybersecurity

# E-Commerce Security Threat Categories

*“An e-commerce security threat is anything that has the potential to cause serious harm to a computer system and the whole e-commerce setup.”*



Each category targets a **different layer** of the e-commerce architecture.

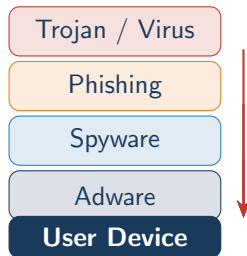
# 1. Client-Side Threats

**Definition:** Security risks targeting the **customer's device, browser, or interaction** with the website.

- Modern e-commerce's interactive pages (carts, payments) create larger attack surfaces
- Targets the *user end* of the transaction

## Common Examples:

- **Trojan Horse** — malware disguised as legitimate software
- **Viruses** — self-replicating malicious code
- **Phishing** — fake sites/emails to steal credentials
- **Adware/Spyware** — tracks and reports user activity



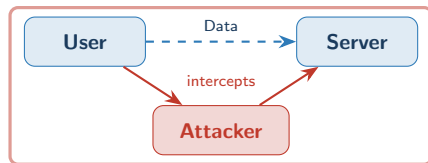
## 2. Communication Channel Threats

**Definition:** Risks arising **in transit** — while data travels across the internet between user and server.

- Targets the *communication link*, not device or server
- Exposes passwords, banking details, and personal data

### Common Attacks:

- **MITM** — secretly intercepts & relays messages
- **Packet Sniffing** — capturing packets on open networks
- **DNS Spoofing** — redirecting users to fake websites



Man-in-the-Middle (MITM)

### 3. Server-Side Threats

**Definition:** Risks targeting the **web server** — the central system storing website data, customer info, and handling transactions.

#### Web Server Threats

Exploit vulnerabilities in server software or configurations to gain unauthorized access (e.g., credential breaches, misconfiguration).

#### CGI Threats

Attackers exploit flaws in server-side scripts to misroute requests, expose sensitive data, or corrupt server output.

#### Database Threats

Unauthorized access leaks customer orders and company data (e.g., SQL Injection attacks).

#### Website Masquerading

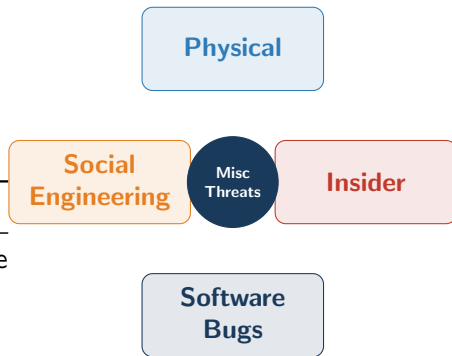
Fake login pages or hijacked real sites used to harvest credentials or manipulate transactions.

## 4. Miscellaneous Threats

**Definition:** Risks that don't fit neatly into client, channel, or server categories — but can still cause serious harm.

Often arise from **human error**, third-party systems, or the physical environment.

| Type               | Example                       |
|--------------------|-------------------------------|
| Physical           | Hardware theft, power failure |
| Insider            | Rogue employees, data leaks   |
| Social Engineering | Pretexting, impersonation     |
| Software Bugs      | Unpatched vulnerabilities     |



# Security Protocols

CCY2001 — Introduction to Cybersecurity

## What Are Security Protocols?

Standardized methods used on the internet to **secure online transactions**, protect user data, and ensure safe communication between buyers and sellers. They provide: **encryption, authentication, integrity, and confidentiality**.

**SSL/TLS**

Transport Security

**HTTPS**

Web Security

**PGP/S-MIME**

Email Security

**SET**

Payment Security

**S-HTTP**

Message Security

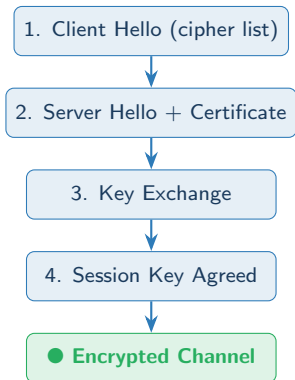
# Secure Socket Layer (SSL / TLS)

- **Most widely used** protocol for securing web communication
- Provides **encryption** between browser and server
- Identified by HTTPS in the URL + padlock icon
- Protects: login credentials, credit card numbers, personal data

## TLS vs. SSL

TLS (Transport Layer Security) is the modern, more secure successor to SSL. Both terms are often used interchangeably in practice.

### SSL Handshake



# HTTPS vs. S-HTTP

## HTTPS (HTTP over SSL/TLS)

- Secures the **entire communication channel**
- Encrypts: URLs, web pages, forms, cookies, all data in transit
- **Global standard** for secure web transactions
- Used for: browsing, shopping carts, payments, account access

## S-HTTP (Secure Hypertext Transfer Protocol)

- Extends HTTP with public-key encryption, authentication, and digital signatures
- Secures **individual messages** rather than the whole channel
- Negotiates encryption type between client and server
- **Less common** than SSL/TLS in practice

**HTTPS:** secures the *channel*

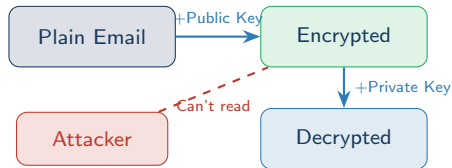


**S-HTTP:** secures the *message*

# PGP and S/MIME — Email Security

**Purpose:** Protect sensitive information exchanged via email — order confirmations, invoices, contracts, and customer support messages. **Key Features:**

- Combination of **symmetric** and **asymmetric** encryption
- **PGP**: “Web of Trust” — users vouch for each other
- **S/MIME**: Certificate Authority (CA)-based trust model
- Provide: encryption, authentication, integrity, non-repudiation



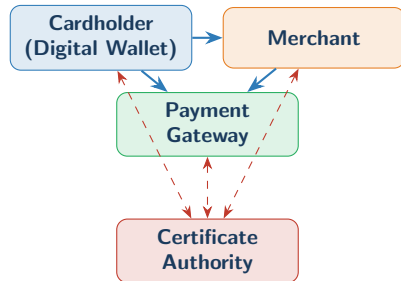
# Secure Electronic Transaction (SET)

## What Is SET?

A secure protocol developed by **MasterCard & Visa** for protecting credit card transactions over the internet. Theoretically the most comprehensive payment security protocol.

## 4 Key Components:

- 1 **Digital Wallet** — secure purchase interface
- 2 **Merchant Software** — secure merchant–bank communication
- 3 **Payment Gateway** — automated payment processing
- 4 **Certificate Authority** — issues digital certificates



# Best Practices — Businesses

CCY2001 — Introduction to Cybersecurity

# Best Practices for E-Commerce Businesses (1/2)

## Implement SSL/TLS Encryption

Encrypt all data between website and users. Ensure the site displays HTTPS and a padlock — a signal of a trusted, protected connection.

## Multi-Factor Authentication (MFA)

Require users to verify identity via two or more methods (e.g., password + one-time passcode) to guard against credential theft.

## Security Audits & Penetration Testing

Regular audits and pen-tests expose vulnerabilities before attackers do. Platforms like Shopify and WooCommerce invest heavily in these practices.

## AI and Machine Learning

AI-driven tools detect threats in real time. Amazon and Alibaba use ML to identify fraudulent transactions and unauthorized access attempts.

# Best Practices for E-Commerce Businesses (2/2)

## Secure Payment Gateways

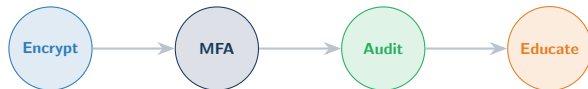
Use trusted processors (PayPal, Stripe, Square) that provide encrypted transactions and comply with **PCI DSS** standards.

## Data Encryption & Tokenization

Encrypt sensitive data and replace it with tokens to minimize exposure in the event of a breach, reducing data misuse risk.

## Employee & Customer Awareness

Human error is a leading cause of incidents. Train staff and educate customers on safe online shopping practices.



# Best Practices — Consumers

CCY2001 — Introduction to Cybersecurity

- ✓ Use **trusted anti-virus** software and keep it updated
- ✓ Use **different passwords** for each platform
- ✓ Create **strong, complex** passwords and update regularly
- ✓ Enable **Two-Factor Authentication (2FA)** where possible
- ✓ **Back up** important data regularly

## Password Strength

Weak: "ab

Medium: "De

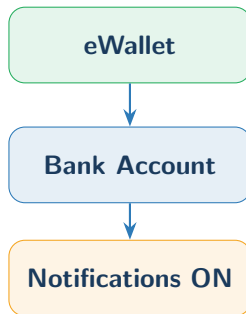
Strong: "mK#9rL&2p

# Secure Your Online Transactions

- Review **bank and eWallet** transactions frequently
- Use a **dedicated or low-limit card** for online purchases
- Enable **SMS/app notifications** for every transaction
- Protect eWallet access with **strong authentication**

## Quick Tip

A low-limit card for online shopping limits your exposure in the event of card compromise.



# Identify Safe Websites & Networks

## Identifying Secure Websites:

- Verify URL starts with `https://`
- Check for padlock icon (🔒) in the browser
- Avoid links from emails or social media
- Be cautious of unrealistic discounts

`https://shop.com` ✓

`http://shop.com` ✗

Public Wi-Fi ✗

VPN on public network ✓

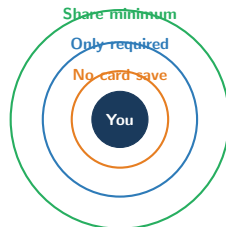
## Safe Network Habits:

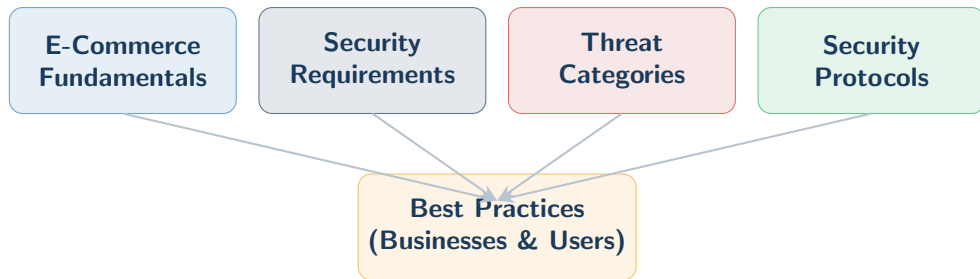
- Download apps from **official stores only**
- Avoid **public Wi-Fi** for sensitive transactions
- Use a **VPN** when on unsecured networks
- **Log out** after completing transactions

# Limit Personal Information Exposure

- Provide **only required information** during purchases
- **Avoid storing card details** on websites or apps
- Read **privacy policies** before sharing data
- Limit app permissions (location, camera, contacts)
- Use **strong device passcodes** and biometric authentication
- Enable **automatic updates** for apps and OS
- Use secure payment gateways (Apple Pay, PayPal, Google Pay)
- **Report incidents** immediately to bank or platform

## Data Minimization





**E-commerce security is a shared responsibility.**

Businesses must implement robust protocols and audits; consumers must practise safe online habits.

# Thank You

Questions?

CCY2001 — Introduction to Cyber Security

